

Aula 6

Segurança da Informação

Prof. Patrick Landal Athayde

1

Fundamentos da segurança em plataformas digitais

2

Segurança da informação como estratégia organizacional

- Segurança da informação: posição estratégica nas organizações (Landin et al., 2025)
- Segurança digital como pilar essencial no mundo conectado
- Garantia de integridade, confidencialidade e disponibilidade dos dados

3

Expansão tecnológica e novos riscos cibernéticos

- Crescimento de plataformas: nuvem, aplicações móveis, IoT
- Ampliação da superfície de ataque e exposição a vulnerabilidades
- Desafios aos modelos tradicionais de proteção

4

Gestão integrada de ameaças e riscos

- Importância de abordar ameaças em todas as áreas da organização (Lima, 2023)
- Análise de riscos e envolvimento das partes interessadas
- Comprometimento e participação ativa

5

Conceitos e arquitetura de plataformas

- Diversidade de ambientes digitais e desafios específicos
- Arquitetura de segurança: políticas, controles e procedimentos
- Defesa em profundidade: múltiplas camadas de proteção
- Particularidades de nuvem e IoT: mobilidade e heterogeneidade

6

Princípios de segurança em múltiplas camadas

- Controles técnicos, administrativos e físicos sobrepostos
- Controle de acesso e autenticação robusta
- Criptografia de dados em trânsito e repouso
- Monitoramento contínuo e segmentação de redes

7

Ciberataques: vetores, técnicas e exploração de vulnerabilidades

8

Compreender o adversário e o cenário de ataques

- Entendimento profundo de ataques cibernéticos como base da defesa
- Finalidade dos ciberataques: revelar pontos cegos (Cano, 2020)
- Impacto de ataques: fragilidades técnicas, culturais e organizacionais

9

Tipos de ataques cibernéticos

- Técnicos: exploração direta de vulnerabilidades (*malware*, força bruta)
- Humanos: engenharia social, *phishing*, *spear phishing*
- Lógicos: manipulação de URLs, *backdoors*, execução não autorizada

10

Vulnerabilidades comuns (OWASP Top 10 – 2025)

- Quebra de controle de acesso
- Falhas de criptografia
- Injeção de código (SQL, NoSQL)
- Design inseguro e exposição de dados
- Configuração incorreta de servidores/APIs (ex.: SSRF)

11

Escalonamento de privilégios

- Vertical: obtenção de direitos administrativos
- Horizontal: acesso a dados de outros usuários
- Riscos: alteração de configurações críticas e comprometimento estrutural

12

Persistência em sistemas comprometidos

- *Backdoors* e serviços disfarçados
- Contas administrativas não monitoradas
- Acesso contínuo para exfiltração, movimentação lateral ou sabotagem
- Mitigação: monitoramento em tempo real, *hardening*, análise comportamental

13

Arquitetura segura e proteção de ambientes operacionais

14

Arquitetura como base da segurança

- Políticas de segurança dependem de arquitetura sólida
- Considerar sistemas operacionais e ambientes de execução
- Importância de *hardening* de servidores e estações de trabalho

15

Segurança em ambientes modernos

- *Containers*, orquestradores e serviços em nuvem
- Crescente uso de microsserviços, APIs abertas e infraestrutura como código
- Novos desafios no ciclo de vida das aplicações

16

Boas práticas de desenvolvimento seguro

- Princípios de *secure coding*
- Ferramentas de análise de código (estática e dinâmica)
- Configurações e permissões seguras

17

Segurança como princípio estruturante

- Segurança desde a concepção até o descarte do sistema
- Integração entre desenvolvimento, operação e proteção
- Vigilância contínua como parte do processo

18

Arquitetura como base da segurança

- ▀ Políticas de segurança dependem de arquitetura sólida
- ▀ Considerar sistemas operacionais e ambientes de execução
- ▀ Importância de *hardening* de servidores e estações de trabalho

19

Testes, monitoramento e resposta a incidentes

20

Resiliência e resposta a incidentes

- ▀ Nenhuma defesa é infalível
- ▀ Detectar, reagir e aprender com incidentes
- ▀ Papel crítico na resiliência organizacional

21

Técnicas e ferramentas de segurança

- ▀ Testes de segurança (*pentests*) e análise de vulnerabilidades
- ▀ Monitoramento de redes e sistemas
- ▀ Protocolos de resposta a incidentes

22

Ferramentas de visibilidade e reação

- ▀ SIEM (Security Information and Event Management)
- ▀ IDS/IPS (Intrusion Detection and Prevention Systems)
- ▀ *Honeypots* para detecção e estudo de ataques

23

Equipes especializadas

- ▀ Red Team: ofensivo
- ▀ Blue Team: defensivo
- ▀ Purple Team: integração ofensiva-defensiva
- ▀ Simulações realistas para treino e avaliação

24

Cultura e maturidade organizacional

- Importância do tempo de resposta
- Integração da inteligência cibernética
- Segurança como parte da cultura institucional

25

***Pentest*, análise de vulnerabilidades e auditorias**

- *Pentest*: simulação controlada de ataques reais
- Identificação proativa de vulnerabilidades
- Auditorias de segurança: falhas técnicas e lacunas processuais
- Análise de vulnerabilidades: scanners e avaliação de riscos
- Ciclo contínuo de melhoria e vigilância de ameaças emergentes

26

Monitoramento e detecção de intrusos

- SIEM: consolidação e correlação de eventos de segurança
- IDS: detecção de intrusões
- IPS: prevenção em tempo real
- Integração com equipes especializadas para resposta rápida

27

Ferramentas de exploração e defesa

- Metasploit: simulação de ataques e análise de vetores
- Nmap: mapeamento de redes e portas abertas
- Wireshark: captura e análise de tráfego de rede
- Burp Suite: testes e análise de vulnerabilidades em aplicações web

28

Conformidade e tendências

29

Segurança da informação e transformações do ecossistema digital

- Influência de mudanças sociais, legais e tecnológicas
- Papel das normas e regulamentações
- Responsabilidade jurídica e ética das organizações

30

Ameaças emergentes

- **Uso malicioso da inteligência artificial**
- **Ransomware-as-a-service (RaaS)**
- **Vulnerabilidades em IoT e *blockchain***

31

Normas e *frameworks* de segurança da informação

- **ISO/IEC 27001**
 - **Requisitos para Sistema de Gestão da Segurança da Informação (SGSI)**

32

Normas e *frameworks* de segurança da informação

- **ISO/IEC 27002**
 - **Controles recomendados para implementação**
 - **Governança, avaliação de riscos, proteção de ativos**
- **NIST Cybersecurity Framework e CIS Controls**
 - **Diretrizes operacionais e técnicas para políticas de segurança**
 - **Estruturação e maturação da segurança**

33

Normas e *frameworks* de segurança da informação

- **MITRE ATT&CK**
 - **Catálogo de táticas e técnicas de adversários cibernéticos**
 - **Apoio no desenvolvimento de defesas e estratégias de detecção e resposta**
- **Integração dos instrumentos**
 - **Ambiente de segurança coerente, auditável e resiliente**
 - **Adaptabilidade a mudanças e ameaças digitais**

34

Legislação aplicável

- **Principais aspectos legais**
 - **Proteção, tratamento e responsabilização de dados pessoais**
 - **Direitos dos titulares e transparência**

35

Legislação aplicável

- **Tendências em 2025**
 - **Ampliação da fiscalização e penalidades**
 - **Controle de acesso granular e auditoria contínua**
 - **Relato transparente de incidentes**
 - **Responsabilidade estendida à cadeia de fornecedores**

36

Ameaças emergentes em segurança da informação

- Ransomware-as-a-Service (RaaS)
 - Democratização do acesso a ferramentas maliciosas
 - Ataques facilitados por agentes menos técnicos mediante pagamento

37

Ameaças emergentes em segurança da informação

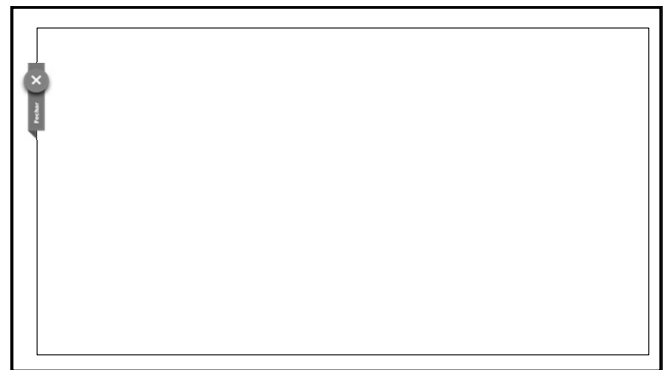
- Inteligência artificial maliciosa
 - Automatização de ataques
 - Criação de *deepfakes* e manipulação comportamental
 - Evasão de defesas tradicionais
 - Necessidade de contramedidas baseadas em IA

38

Ameaças emergentes em segurança da informação

- Ataques a IoT (Internet das Coisas)
 - Vulnerabilidades por dispersão e baixa proteção dos dispositivos
 - Falhas de configuração comuns
- Ataques a *blockchain*
 - Segurança criptográfica sólida, mas riscos nas camadas de aplicação
 - Contratos inteligentes vulneráveis

39



40